Lesson notes · for you

Check before you trust a model

AI security · Upper secondary · Lesson 4

Time
20 min

Materials
Paper and a pen; A family phone with its owner, or your club's computer; A phone or computer with Darsi, if you have one, for the lab and the code

Learning goals

- Explain how the AI supply chain can be attacked.
- Compute and compare a SHA-256 fingerprint in Python.
- Explain what a signature adds, and keep a model list.

Activity: Check the chain

1. Warm-up (3 min): Think of three apps on your phone (or a family phone, with its owner). Write where each one came from: the official store, a file someone shared, or a website.
2. Fingerprint (7 min): In Darsi's code step, compute the fingerprint of b"leafnet v2", then of b"leafnet v3", and compare. No device? Make a paper fingerprint: add up the digits of a long number, change one digit, and see the total change.
3. List (5 min): Start a model list with four columns: name, version, where it came from, and the first eight characters of its fingerprint if you have it.
4. Share (5 min): Swap lists with a partner. Which entry would you remove or replace from the official source, and why?

Only look at a family phone with its owner, and don't install anything new during the activity.

Discussion

- Why can't a fingerprint alone prove who made a file?
- Why are free “pro” versions shared in groups so risky?
- What would you put on your family's model list?

Check yourself

- Write the two checks you'd do before running a downloaded model, and what each one proves.

Try it this week
With the owner, look at the AI apps on a family phone. For each one, write where it came from: the official store, a shared file or a website. Remove any shared file you can't check, and start your own model list.

Worksheet

Check before you trust a model

AI security · Upper secondary · Lesson 4

Name _____ Class _____ Date _____

1 **A model's fingerprint matches the one posted right next to it, on a site you don't know. Can you trust it?**

- ◯ Not yet: check the official source and the signature
- ◯ Yes: the fingerprint matches
- ◯ Yes, if it runs without errors

2 **Complete fp(data) so it returns the SHA-256 fingerprint of the data as 64 hex characters.**

```
import hashlib, binascii

def fp(data):
    h = hashlib._____(data).digest()
    return binascii._____(h).decode()
```

Word bank: `hexlify` `md5` `digest` `sha256` `lower`

3 **What does this program print?**

Here goes the code from question 2, with its gaps filled in.

```
a = fp(b"model")
b = fp(b"Model")
print(len(a), a == b)
```

- ◯ 5 False
- ◯ 64 False
- ◯ 64 True

4 **Your club keeps a model list: each model's name and its published fingerprint, in the dictionary LIST, so LIST[name] is that model's fingerprint. Write verify(name, data): return "unknown" if the model isn't on the list, "changed" if the file's fingerprint doesn't match, and "ok" otherwise.**

Here goes the code from question 2, with its gaps filled in.

```
LIST = {"leafnet": fp(b"leafnet v2")}
def verify(name, data):
    # "unknown", "changed" or "ok"
    return "ok"
print(verify("leafnet", b"leafnet v3"))
```

Write your program:

5 **Match each supply-chain risk to the check that catches it.**

A fake copy from an impostor	• • • •	Prefer files that hold only numbers
A file changed on the way	• • • •	Keep a model list
A file that runs code when loaded	• • • •	Check the publisher's signature
Forgetting what you installed	• • • •	Compare the fingerprint

✎ **Which apps or AI tools on your phone came from a shared file or a website, not the official store? How could you check them?**

Check your answers

Check before you trust a model

AI security · Upper secondary · Lesson 4

1 **Not yet: check the official source and the signature**

A fingerprint only means something if it comes from the real publisher.

2

```
import hashlib, binascii

def fp(data):
    h = hashlib.sha256(data).digest()
    return binascii.hexlify(h).decode()
```

hashlib.sha256 computes the 32-byte fingerprint, and binascii.hexlify turns those bytes into 64 hex characters; .decode() makes them text you can compare.

3 **64 False**

Every SHA-256 fingerprint is 64 hex characters long, however short the data.

4

```
import hashlib, binascii
def fp(data):
    h = hashlib.sha256(data).digest()
    return binascii.hexlify(h).decode()
LIST = {"leafnet": fp(b"leafnet v2")}
def verify(name, data):
    if name not in LIST:
        return "unknown"
    if fp(data) != LIST[name]:
        return "changed"
    return "ok"
print(verify("leafnet", b"leafnet v3"))
```

A model you never listed is unknown, so you don't run it.

5

A fake copy from an impostor — Check the publisher's signature

A file changed on the way — Compare the fingerprint

A file that runs code when loaded — Prefer files that hold only numbers

Forgetting what you installed — Keep a model list

Each risk has its check: a signature shows who published a file, a fingerprint shows it didn't change, number-only formats can't run code, and a list shows what you have and when it changed.